



Encryption and Key Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	5
2. Functional Scope and Target Groups	6
2.1. Functional scope of applicability	6
2.2. Target groups	6
2.3. Transition period	7
3. Definitions	8
3.1. Requirements	8
3.2. Explanation of requirements and key definitions	9
4. Requirements	10
4.1. Requirements	10
5. Roles and Responsibilities	36
5.1. Creator	36
5.2. Guideline Owner	36
6. Appendix	37
6.1. Contact Information	37
6.2. Document History	37
6.3. Related Written Rules	37
6.4. Abbreviations	38

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Encryption and Key Management Guideline (hereinafter "Guideline") establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks .	4.3

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	CIO / COO Division; Chief Risk Officer Area; Chief Compliance Officer Area; or any other area that owns Encryption and Key Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Encryption and Key Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee the strategic direction and policy enforcement related to encryption and key management.
ICT Operational Management	To implement and maintain technical measures on encryption and key management.
Business Management	To manage the encryption and key management related risks and consequent tracking and reporting.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “Valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “Valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirements

ID: 1 (version 2.0)	Procedure, Development and Governance
1 DOR.ICT.EKM.PDG.001	An Encryption and Key Management procedure must be defined, documented, and implemented to ensure company data is protected. The procedure must include controls, rules, and guidance for the implementation.
1.1 DOR.ICT.EKM.PDG.002	Encryption and Key management controls and guidance must entail rules around preservation of confidentiality, integrity, availability, and authenticity of data. Asset-Types: Business Process Key References: DORA RTS RMF A.6.1
1.2 DOR.ICT.EKM.PDG.003	In instances where adherence to leading practices, standards, or the utilization of the most reliable techniques, including the updating or changing of cryptographic technology, is not feasible, Encryption and Key management controls, rules and guidance must entail mitigation and monitoring measures, accompanied by a reasoned explanation for the deviation. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.5
1.3 DOR.ICT.EKM.PDG.004	Encryption and Key management procedure must entail activities on review, approval, implementation, and communication of cryptographic and key management technology changes. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.4

ID: 2 (version 2.0)	Selection and implementation of cryptographic measures
2 DOR.ICT.EKM.SCM.001	Cryptographic measures selection, implementation must be aligned with recognized standards, applicable legislation, and legal entities' approval. They must provide sufficient strength and commensurate to applicable data classification.

2.1 DOR.ICT.EKM.SCM.002	Requirements of cryptographic measures regarding strength and quality to be legal entity approved: Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
2.1.1 DOR.ICT.EKM.SCM.003	Key lengths, encryption schemes and allowed hash functions must comply with the requirements specified in BSI TR 02102-1, 23.01.2026³, preferably AES-256 GCM, with the following exemption: the key length for the cryptographic algorithms DLIES, DSA and RSA must be at least 2000 bits and ≥ 3000 bits if possible. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.3)
2.1.2 DOR.ICT.EKM.SCM.004	The cryptographic measures must be selected in compliance with all relevant agreements, legislations, and regulations as reflected in this guideline, based on recognized international, European, harmonized, or national standards, and the classification of IT Assets. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.3)
2.1.3 DOR.ICT.EKM.SCM.005	Requirements regarding certificates for payment services: If certificates are used for the purpose of identification within a payment service, they must rely on qualified certificates for electronic seals or on qualified certificates for website authentication. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
2.1.4 DOR.ICT.EKM.SCM.006	Requirements regarding key storage: The key storage must be commensurate to the strength and quality of the cryptographic measure used and the use case for which the key is applied. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device,

³ Future enhancements for quantum-safe cryptography can be aligned with project-specific timelines and implementation guidance defined in upcoming phases.

	Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
2.1.5 DOR.ICT.EKM.SCM.007	Risk Analysis: Based on the risk analysis, requirements for the strength and quality of the cryptographic measures must be defined, implemented, ensuring that appropriate BSI approved cryptographic measures are applied. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
2.2 DOR.ICT.EKM.SCM.008	It must be ensured that only cryptographic measures approved by legal entity are used (see Control ID 2.1, Selection of cryptographic measures). If these standards cannot be met, mitigation and monitoring measures must be adopted to ensure cyber resiliency. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.3)
2.3 DOR.ICT.EKM.SCM.009	Requirements regarding key management: All cryptographic certificates which are used to secure the communication should be issued by a Public Key Infrastructure (PKI) with the exception of SSH keys. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
2.4 DOR.ICT.EKM.SCM.010	<u>Additional for IT Assets subject to MAS TRMG:</u> Transaction signing must be implemented for authorizing high-risk activities. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 3 (version 2.0)	Review, assessment and monitoring of cryptographic measures and products
3 DOR.ICT.EKM.RAM.001	Cryptographic measures and products must undergo regular assessment, monitoring regarding compliance with applicable standards, legislation, and adherence with developments in cryptanalysis to ensure they remain resilient against cyber threats.

3.1 DOR.ICT.EKM.RAM.002	The cryptographic measures implemented must be reviewed/ reassessed at least every 12 months. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
3.2 DOR.ICT.EKM.RAM.003	For cryptographic measures and products which do not meet applicable technical or legal requirements or cannot mitigate applicable threats from cryptanalysis development, the potential risks must be assessed and treated. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.4)

ID: 4 (version 2.0)	Documentation, inventory of key and cryptographic measures
4 DOR.ICT.EKM.DCM.001	Documentation of cryptographic measures, cryptographic inventory and Cryptographic Bill of Materials (CBOM), PKI architecture, connection paths with corresponding key and certificate register must be established and regularly maintained to ensure proper operation and compliance.
4.1 DOR.ICT.EKM.DCM.002	The cryptographic measures must be documented to ensure that they are safely operated, and an overview of the implemented measures is provided: Details of all algorithms and protocols used for the protection of classified data and the keys used should be documented. More precisely, for algorithms and protocols at least the aspects bit security, protection level, standard as well as usage and for keys the strength, expiry date and usage must be recorded. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
4.2 DOR.ICT.EKM.DCM.003	The PKIs must be documented to ensure their safe operation. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

4.2.1 DOR.ICT.EKM.DCM.004	For each PKI a governance model for generation, distribution and management of cryptographic keys must be in place and documented, providing requirements for the complete life cycle of certificates and keys. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
4.2.2 DOR.ICT.EKM.DCM.005	For each certificate authority, methods and processes to be implemented must be described to meet the requirements demanded by the governance model. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
4.2.3 DOR.ICT.EKM.DCM.006	The documentation of PKIs should ensure that the keys are securely managed, conflicts of interest are strictly avoided and a clear role concept with separation of duties is in place to avoid misuse during the creation and administration of cryptographic keys in accordance with Identity and Access Management Guideline. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
4.3 DOR.ICT.EKM.DCM.007	Connection paths and corresponding keys without central validation must be documented in an auditable format to ensure proper compliance of authorizations in addition to providing the ability to remediate any access violations. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
4.4 DOR.ICT.EKM.DCM.008	A register for all certificates and certificate-storing devices for at least IT Assets supporting critical or important functions must be in place and up to date. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.4)

4.5 DOR.ICT.EKM.DCM.009	A cryptographic inventory should be established, implemented, and maintained for all applications and applicable infrastructure components within ICT systems. The cryptographic inventory should represent the authoritative control for documenting, governing, and managing the use of cryptographic measures across the ICT estate. It should be complete, continuously updated, and aligned with the lifecycle of systems and cryptographic assets. At a minimum, the cryptographic inventory should include: • (31.01.2027) • Asset (application or infrastructure component) • Owner and responsible organizational unit • Description of cryptographic usage and purpose • Protocols and cryptographic functions used • Location (system, environment, or service) • Relevant lifecycle attributes (e.g. creation, validity, rotation or expiry where applicable) A Cryptographic Bill of Materials (CBOM) should be created and maintained for applications and applicable infrastructure components as a supporting artefact to the cryptographic inventory. The CBOM should provide a structured and machine-readable representation of cryptographic components embedded in software and systems and should be used to support the completeness and accuracy of the cryptographic inventory. CBOM should be used as an input source to populate and maintain the cryptographic inventory and appropriate processes should ensure regular synchronization and consistency between CBOM artefacts and the central inventory. At a minimum, the CBOM should include: • (31.01.2027) • Algorithms (including parameters and mode of operation) • Cryptographic libraries and modules • Key metadata (e.g. key length, usage, and storage location where detectable) • Certificates (issuer, subject, signature algorithm, validity period, chain of trust, key usage, and status) • Protocol implementations • Dependencies between cryptographic components Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.4
---------------------------------------	--

ID: 5 (version 2.0)	Protection of data in transit
5 DOR.ICT.EKM.PDT.001	Data in transit must be protected in accordance with its classification and risk analysis and exchanged through secure network only.
5.1 DOR.ICT.EKM.PDT.002	Data in transit must be protected depending on its classification based on the results of the approved data classification and risk analysis.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.2a, A.6.2c
5.1.1 DOR.ICT.EKM.PDT.003	If data communicated within internal network is classified as “critical” or “major”⁴ with respect to confidentiality and/or integrity and/or authenticity or “Data Crown Jewel”⁵ or when the visible label of the data is “strictly confidential”, or “confidential”, it should be protected by cryptographic measures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.2a, A.6.2c
5.1.2 DOR.ICT.EKM.PDT.004	The approach to the data in transit cryptographic protection should consider technical risk analysis for at least the following scenarios: connection from a compromised or malicious software client, connection to a compromised or malicious server, “man-in-the middle” attack, data theft by traffic sniffing. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.6.2a, A.6.2c
5.1.3 DOR.ICT.EKM.PDT.005	WLAN: Only access solutions for WLAN must be applied using legal entity approved cryptographic measures to ensure authenticity. Furthermore, the communication must be encrypted (see below, communication within internal network) to provide confidentiality. Asset-Types: Information, Business Process, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
5.1.4 DOR.ICT.EKM.PDT.006	Port Security: Secure cryptographic measures should be used to ensure that only legal entity owned assets are connected to internal network (excl. legal entity guests) ensuring that confidentiality, integrity, and authenticity are preserved. Asset-Types: Information, Business Process, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
5.1.5 DOR.ICT.EKM.PDT.007	Internet of Things and Operational Technology: Data communication should be protected regarding their confidentiality, integrity, and authenticity either by using the cryptographic measures applied for the

⁴ The impact classification can be found in ICT Risk Management guideline (requirement ID 4.2) or Information Risk Management Procedure (chapter 4.3)

⁵ The definition of Data Crown Jewel can be found in Data Security Governance guideline (requirement ID 2.1)

	communication within internal network, by establishing a Virtual Private Network (VPN) based connection or other equivalent technologies. Asset-Types: Information, Business Process, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
5.1.6 DOR.ICT.EKM.PDT.008	Emails: Emails should be protected regarding confidentiality, integrity and authenticity using legal entity approved cryptographic measures and keys generated and managed by a PKI. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 6 (version 2.0)	Protection of data at rest
6 DOR.ICT.EKM.DAR.001	Protection of data at rest and rules for encryption of data must be in place and aligned with data classification and risk analysis.
6.1 DOR.ICT.EKM.DAR.002	Data stored inside of internal infrastructure or legal entity approved data centers must be protected with respect to confidentiality, integrity and authenticity depending on its classification and risk analysis. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware, Datacenter Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.1 DOR.ICT.EKM.DAR.003	Independent of the classification the following data must be protected by cryptographic measures to preserve confidentiality: personalized security credentials. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Storage Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.2 DOR.ICT.EKM.DAR.004	Data stored within internal infrastructure classified as “critical” or “major”³ with respect to confidentiality and/or integrity and/or authenticity or “Data Crown Jewel”⁴ or where the visible label of the data is “strictly confidential” or “confidential”, should be protected by cryptographic measures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage Key References: DORA RTS RMF A.6.2a)

6.1.3 DOR.ICT.EKM.DAR.005	The approach to the data at rest cryptographic protection should consider technical risk assessment for at least the following scenarios: equipment theft, malicious actions of underlying platform administrator. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.6.2a)
6.1.4 DOR.ICT.EKM.DAR.006	The storage of mobile devices and storage media must be fully encrypted using legal entity approved cryptographic measures to preserve their confidentiality. Asset-Types: Information, Business Process, End User Device, Mobile Device, Storage Media Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.5 DOR.ICT.EKM.DAR.007	Backups: Backups must be protected from loss of confidentiality, integrity, and authenticity. Depending on the information classification, cryptographic measures must be used. Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Storage Media, Storage Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.6 DOR.ICT.EKM.DAR.008	Archives: Archives must be protected from loss of confidentiality, integrity, and authenticity. Depending on the information classification, cryptographic measures must be used. Furthermore, long-term security must be ensured, data is protected and can be accessed during its entire legally obligated archival period. Asset-Types: Information, Cloud Appliance, Cloud PaaS, Storage Media, Storage Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.7 DOR.ICT.EKM.DAR.009	Stationary Devices: The storage of all Stationary Devices containing critical data should be protected regarding confidentiality using legal entity approved cryptographic measures. Asset-Types: Information, Business Process, Other Device, Datacenter Key References: ISO 27001:2022 Cor 202203 A.8.24
6.1.8 DOR.ICT.EKM.DAR.010	Internal Servers: File-, database-, mail-, application- and web servers, internal data centers, on-premises clouds as well as collaboration platforms should be protected regarding confidentiality using legal entity approved cryptographic measures providing full disk or partitions encryption. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203
6.2 DOR.ICT.EKM.DAR.011	Data at rest stored outside of internal infrastructure or legal entity approved data centers must be protected depending on its classification and risk analysis.

	Asset-Types: Information, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage, Network Connection Key References: DORA RTS RMF A.6.2a)
6.2.1 DOR.ICT.EKM.DAR.012	If data is classified as “minor”, “major” or “critical”³ with respect to confidentiality or “Data Crown Jewel”⁴ or when the visible label of the data is “internal”, “external”, “confidential” or “strictly confidential”, it must be encrypted by the legal entity using its approved cryptographic measures, such that only the legal entity can decrypt the data to preserve its confidentiality (the data is stored in encrypted form in external servers). Asset-Types: Information, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage, Network Connection Key References: DORA RTS RMF A.6.2a)
6.2.2 DOR.ICT.EKM.DAR.013	The approach to the data at rest cryptographic protection should consider technical risk analysis for at least the following scenarios: equipment theft, malicious actions of underlying platform administrator, cyberattack on the external infrastructure provider. Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Storage, Network Connection Key References: DORA RTS RMF A.6.2a)
6.2.3 DOR.ICT.EKM.DAR.014	Legal entity approved cryptographic measures must be used to ensure that only authorized persons access the ICT Systems to preserve integrity and authenticity. Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 7 (version 2.0)	Protection of data in use
7 DOR.ICT.EKM.DIU.001	Protection of data in use must be in place and aligned with data classification and risk analysis.
7.1 DOR.ICT.EKM.DIU.002	Rules for the encryption of data in use must be defined, documented based on the results of the approved data classification and risk analysis, for example, rules for confidential computing. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.6.2b)
7.2 DOR.ICT.EKM.DIU.003	In case encryption of data in use is not possible, the data must be processed in a separated and protected environment or take other equivalent measures that ensure confidentiality, integrity, authenticity, and availability of data if possible. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud

	Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.6.2b)
--	---

ID: 8 (version 2.0)	Key Management and Governance
8 DOR.ICT.EKM.KMG.001	It must be ensured that requirements and guidance for cryptographic key management are in place.
8.1 DOR.ICT.EKM.KMG.002	Requirements for cryptographic key management must cover the entire lifecycle of cryptographic keys, including generating, renewing, storing, backing up, archiving, retrieving, transmitting, retiring, revoking, and destroying those cryptographic keys. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.6.2d
8.2 DOR.ICT.EKM.KMG.003	Requirements must specify how cryptographic keys are correctly used and protected. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.7.1
8.3 DOR.ICT.EKM.KMG.004	The cryptographic keys should be dedicated to a single purpose. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.24
8.3.1 DOR.ICT.EKM.KMG.005	The key should be either used for encryption or for digital signatures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.24

8.3.2 DOR.ICT.EKM.KMG.006	<u>Additional PKI-specific and certificate-related requirements:</u> Certificates used for authentication of users or entities should not be used for digital signatures or non-repudiation. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.24
8.3.3 DOR.ICT.EKM.KMG.007	Where an IT Application uses certificates for user authentication and digital signatures, two separate keys and certificates should be issued to each user. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.24
8.3.4 DOR.ICT.EKM.KMG.008	If a digital certificate to a key pair is generated it should clearly indicate the intended usage using X509 key usage and extended key usage attributes. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.24
8.4 DOR.ICT.EKM.KMG.009	Customer keys or other master keys must be generated and stored under legal entity control whether on-premises or in the cloud. Asset-Types: Information, Business Process, Certificate, Hardware Appliance, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 9 (version 2.0)	Key generation
9 DOR.ICT.EKM.KGN.001	It must be ensured that key generation is performed appropriately with sufficient security measures and that generated keys meet applicable strength and quality requirements.
9.1 DOR.ICT.EKM.KGN.002	The key generation and utilized random number generators must comply with the requirements specified in BSI standards or by using hardware coming with a NIST FIPS 140-2 validation and NIST FIPS 140-3 validation should be used if possible. For detailed requirements on key generation and random number generator, please refer to BSI TR 02102-1, 23.01.2026 and NIST SP 800-90A, 06.2015. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance,

	Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.2 DOR.ICT.EKM.KGN.003	The security parameters of the keys must be chosen such that they provide the strength and quality demanded by the legal entity. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.3 DOR.ICT.EKM.KGN.004	When keys used in the Red Segregation Area are generated, at least two persons should be present and provide a formal documentation of the steps performed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.4 DOR.ICT.EKM.KGN.005	If users generate their own keys, they should be guided in generating key material, especially when they decide for parameters or add randomness. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage Key References: ISO 27001:2022 Cor 202203 A.8.24
9.5 DOR.ICT.EKM.KGN.006	Keys should only be created with the intent of establishing an approved trust relationship and must be deleted if approval of the request has been denied or revoked. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6 DOR.ICT.EKM.KGN.007	<u>Additional PKI-specific and certificate-related requirements:</u> Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6.1 DOR.ICT.EKM.KGN.008	The key generation must be carried out using a secure cryptographic key generator.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6.2 DOR.ICT.EKM.KGN.009	The hardware used to generate the keys must be protected against unauthorized access, theft, or damage by appropriate physical and organizational measures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6.3 DOR.ICT.EKM.KGN.010	Key-encrypting keys (keys used to protect multiple keys) must be at least as strong as the data-encrypting keys they protect. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6.4 DOR.ICT.EKM.KGN.011	After key generation, all data used during this process should be destroyed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.6.5 DOR.ICT.EKM.KGN.012	For long-living keys or sensitive keys, it should be ensured that no single individual knows the key in its entirety or has access to all the components generating the keys. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.7 DOR.ICT.EKM.KGN.013	<u>Additional SSH-key-related requirements:</u> Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

9.7.1 DOR.ICT.EKM.KGN.014	SSH-keys generation must be carried out using a secure cryptographic key generator, which ensures enough randomness and prevents manipulation. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.7.2 DOR.ICT.EKM.KGN.015	SSH-key pairs should be created on the source system where the private key remains. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
9.7.3 DOR.ICT.EKM.KGN.016	Least privilege principle and measures to reduce risks related to misuse should be technically enforced for generated SSH-keys. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Desktop Application, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 10 (version 2.0)	Key distribution
10 DOR.ICT.EKM.KDS.001	Keys must be protected when distributed.
10.1 DOR.ICT.EKM.KDS.002	It must be ensured that only authorized key holders receive secret keys. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.2 DOR.ICT.EKM.KDS.003	The key holder should formally acknowledge that they understand and accept their key-custodian responsibilities. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host

	Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.3 DOR.ICT.EKM.KDS.004	<u>Additional PKI-specific and certificate-related requirements:</u>
10.3.1 DOR.ICT.EKM.KDS.005	During key distribution, the same protection level as required for key storage must be met. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.4 DOR.ICT.EKM.KDS.006	<u>Additional SSH-key-related requirements:</u>
10.4.1 DOR.ICT.EKM.KDS.007	Private key distribution process must be done in encrypted form, and it must be ensured that the private key is kept confidential during the process. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.4.2 DOR.ICT.EKM.KDS.008	Private key distribution must be prevented to avoid exposure, if applicable. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.4.3 DOR.ICT.EKM.KDS.009	Public keys must only be distributed by authorized users for the establishment of approved trust-relationships. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
10.4.4 DOR.ICT.EKM.KDS.010	Established trust-relationships must be documented to ensure audit and remediation activities. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other

	Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
--	--

ID: 11 (version 2.0)	Key installation
11 DOR.ICT.EKM.INS.001	Keys must be checked prior to installation and deployment.
11.1 DOR.ICT.EKM.INS.002	Before key installation, the key holder receiving the key must verify its integrity and authenticity, following a risk-based approach. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
11.2 DOR.ICT.EKM.INS.003	<u>Additional SSH-key-related requirements:</u> When the SSH target Account Owner receives a key deployment request the following attributes must be checked: It must be verified whether the SSH-key pair expiration date has not been met yet and no deletion date is documented for the SSH-key pair. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 12 (version 2.0)	Key storage
12 DOR.ICT.EKM.STO.001	Cryptographic keys must be physically and/or logically protected against modification, theft, loss, and deletion, in accordance with the classification level of the data they protect and aligned with risk-based approach.
12.1 DOR.ICT.EKM.STO.002	The keys must be stored such that the strength and quality demanded by the legal entity is provided. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.2 DOR.ICT.EKM.STO.003	Key-encrypting keys must be stored separately from data-encrypting keys. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device,

	Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.3 DOR.ICT.EKM.STO.004	Private keys should remain non-exportable or vaulted. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.4 DOR.ICT.EKM.STO.005	In case cryptographic keys are managed by the Asset Owners themselves, all operations must be recorded in a log and forwarded to central storage. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5 DOR.ICT.EKM.STO.006	<u>Additional PKI-specific and certificate-related requirements:</u>
12.5.1 DOR.ICT.EKM.STO.007	Hardware storing key material must be protected from loss, theft, or damage by appropriate organizational and physical measures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.2 DOR.ICT.EKM.STO.008	Hardware storing keys must be certified to be sufficiently tamper-proof. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.3 DOR.ICT.EKM.STO.009	Access to key-encrypting keys must be protected using the multiple-eyes principle. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.4 DOR.ICT.EKM.STO.010	Access to systems storing key material must be limited to the need-to-know principle for authorized people.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.5 DOR.ICT.EKM.STO.011	Private keys must only be stored in encrypted form. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.6 DOR.ICT.EKM.STO.012	Cryptographic keys that are used for long periods of time or pose a high risk in case of key leakage, must be stored outside of the used ICT Systems. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.7 DOR.ICT.EKM.STO.013	If long-living keys are stored, they should be protected by the multiple-eyes principle. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.5.8 DOR.ICT.EKM.STO.014	If the key is used to protect data classified as “critical”³ with respect to confidentiality or “Data Crown Jewel”⁴ or the visible label of the data is “strictly confidential”, it should be stored on a hardware security module. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
12.6 DOR.ICT.EKM.STO.015	<u>Additional SSH-key-related requirements:</u> Access to private SSH-keys must be restricted to authorized users and should be limited to read access, if applicable. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other

	Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
--	--

ID: 13 (version 2.0)	Key renewal/rotation
13 DOR.ICT.EKM.KRN.001	Key renewal and session key change should be performed regularly to avoid compromise over time.
13.1 DOR.ICT.EKM.KRN.002	To address potential compromise of key material over time, a periodic key renewal should be performed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.1.1 DOR.ICT.EKM.KRN.003	For each use of cryptographic measures, the validity period of keys should be determined by consideration of the cryptographic algorithms and parameters, the threat vectors and landscape, the sensitivity and protection requirements of the data, the frequency, volume and use case of key usage, the level of security of the key storage and the operational criticality. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.1.2 DOR.ICT.EKM.KRN.004	The process to renew keys should be initiated early enough to ensure that a new key is in place before the old key expires. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.1.3 DOR.ICT.EKM.KRN.005	The new keys should be generated independently from the previous key. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.1.4 DOR.ICT.EKM.KRN.006	<u>Additional SSH-key-related requirements:</u> SSH-key pairs held by a group of individuals should be changed whenever an individual is removed from the group.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.2 DOR.ICT.EKM.KRN.007	Session keys should be changed after a specific time or number of encrypted packets, considering risk analysis. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
13.3 DOR.ICT.EKM.KRN.008	PKI-specific and certificate-related requirements: Certificates must be renewed in an appropriate time before they expire. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.5

ID: 14 (version 2.0)	Key backup and archiving
14 DOR.ICT.EKM.BCK.001	Cryptographic keys must be securely protected in backup, archive and their availability must be ensured when needed.
14.1 DOR.ICT.EKM.BCK.002	Cryptographic keys must be protected when backed up and/or archived. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
14.1.1 DOR.ICT.EKM.BCK.003	The same level of protection as for key storage must be provided for the backed up and archived data as well. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
14.1.2 DOR.ICT.EKM.BCK.004	Keys must be deposited (respectively backed up and/or archived) when they are used for encryption or, in case of a key loss, access to the encrypted data is still required.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
14.2 DOR.ICT.EKM.BCK.005	It must be ensured that keys can be restored and clarified from whom the data can be accessed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
14.2.1 DOR.ICT.EKM.BCK.006	Based on the backup, in case of a disaster or media failure the keys must be recoverable to quickly re-establish products and to access encrypted information. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
14.2.2 DOR.ICT.EKM.BCK.007	Processes should be provided on how to react in case of a key loss or failure, malfunction, or breakdown of cryptographic products. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 15 (version 2.0)	ICT-related Incidents involving cryptographic keys
15 DOR.ICT.EKM.KIN.001	It must be ensured that ICT-related Incidents involving cryptographic keys are understood, identified and that countermeasures are available for overall ICT-related Incident response.
15.1 DOR.ICT.EKM.KIN.002	Possible ICT-related Incidents involving cases such as loss or failure of cryptographic keys must be identified in advance. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.3)

15.2 DOR.ICT.EKM.KIN.003	Processes and countermeasures must be defined on how to react in case of a key loss, key compromise or failure, malfunction, or breakdown of cryptographic products. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.3)
15.2.1 DOR.ICT.EKM.KIN.004	<u>Additional PKI-specific and certificate-related requirements:</u> Possible countermeasures for these ICT-related Incidents include the following: revocation of the key and adding it to the Certificate Revocation List (CRL), deletion of data encrypted with forged keys, prolonging the security by re-encryption and building of signature chains. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.3)
15.3 DOR.ICT.EKM.KIN.005	Parties that are affected by key compromise, such as Information Owners, must be informed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.7.3)

ID: 16 (version 2.0)	Key deletion
16 DOR.ICT.EKM.KDE.001	Key deletion must be performed securely to ensure non-recoverability.
16.1 DOR.ICT.EKM.KDE.002	If keys are no longer required, they must be deleted in a secure way. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
16.2 DOR.ICT.EKM.KDE.003	<u>PKI-specific and certificate-related requirements:</u> It should be prevented that deleted keys can be recovered by any party in case keys are stored in a Hardware Secure Module (HSM).

	Asset-Types: Information, Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
--	--

ID: 17 (version 2.0)	Cloud-specific encryption requirements
17 DOR.ICT.EKM.CLD.001	It must be ensured that appropriate cryptographic measures and cryptographic key management are in place for cloud.
17.1 DOR.ICT.EKM.CLD.002	Rules for secure cloud cryptographic key management including key generation, storage and sharing of keys, must be defined and implemented. Asset-Types: Information, Business Process, SaaS, Certificate, Cloud Appliance, Cloud PaaS, Storage, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.24
17.1.1 DOR.ICT.EKM.CLD.003	For IT Assets classified as major and critical regarding confidentiality or systems that process, store Data crown jewels⁴, the key generation should be done inside hardware security modules (HSM) that complies with FIPS 140-2 Level 3 or with FIPS 140-3 Level 3 if possible. Asset-Types: Information, Business Process, Certificate, Cloud Appliance, Cloud PaaS Key References: /
17.1.2 DOR.ICT.EKM.CLD.004	The default key storage of the CSP may be used for negligible and minor³ regarding confidentiality of classified IT Assets for the key generation. Asset-Types: Information, Cloud Appliance, Cloud PaaS, Storage Key References: ISO 27001:2022 Cor 202203 A.8.24
17.1.3 DOR.ICT.EKM.CLD.005	Keys must be shared as cryptograms, e.g., encrypted with the addressee's public key via secure e-mail or secure file transfer or via HSM native envelope encryption. Other mechanisms for key distribution are not acceptable. Asset-Types: Information, Business Process, SaaS, Certificate, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.8.24
17.1.4 DOR.ICT.EKM.CLD.006	It must be contractually ensured that cloud service providers provide the ability for the covered legal entity to manage own data encryption keys. Asset-Types: Information, Business Process, Supplier Key References: CCM requirement CEK08
17.1.5 DOR.ICT.EKM.CLD.007	The legal entity must ensure that API keys are secure. Asset-Types: Information, SaaS, Certificate, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.8.22
17.2 DOR.ICT.EKM.CLD.008	It must be ensured that connections are established using industry standard protocols including but not limited to HTTPS, IPSec, SSH. Connection in public networks must always be encrypted.

	Asset-Types: Information, SaaS, Certificate, Cloud Appliance, Cloud PaaS, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.22
17.3 DOR.ICT.EKM.CLD.009	It must be ensured that backups performed using cloud native services are encrypted. Asset-Types: Information, Business Process, SaaS, Certificate, Cloud Appliance, Cloud PaaS, Storage Key References: ISO 27001:2022 Cor 202203 A.8.22

ID: 18 (version 2.0)	Certificate validation requirements
18 DOR.ICT.EKM.CER.001	When encrypting or verifying messages, it must be ensured that the certificate meets security requirements by checking the key holder's data, the validity of the certificate chain, expiration dates, and the Certificate Revocation List (CRL); report any non-compliant certificates as ICT-related Incidents.
18.1 DOR.ICT.EKM.CER.002	<u>PKI-specific and certificate-related requirements:</u> When a user encrypts the message sent to a receiver or verifies a received signed message, it must be checked whether the certificate fulfills the necessary security requirements. Certificates which do not meet the requirements listed below must be reported as an ICT-related Incident. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
18.1.1 DOR.ICT.EKM.CER.003	It must be verified whether the data of the key holder matches the subject or subject alternative name contained in the certificate. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
18.1.2 DOR.ICT.EKM.CER.004	It must be verified whether the whole certificate chain (up until the root-CA) is valid. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
18.1.3 DOR.ICT.EKM.CER.005	It must be verified whether the validity of the certificates has not yet expired.

	Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24
18.1.4 DOR.ICT.EKM.CER.006	It must be verified whether the certificates are not listed on the Certificate Revocation List (CRL) containing a list of all revoked certificates. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.24

ID: 19 (version 2.0)	Electronic messaging controls
19 DOR.ICT.EKM.EMC.001	It must be ensured that all business information transfers use cryptographic measures to meet confidentiality, integrity, authenticity, and non-repudiation requirements, with encryption for "strictly confidential" data or Data Crown Jewel⁴ being implemented where possible.
19.1 DOR.ICT.EKM.EMC.002	Solutions for electronic business information transfer must provide adequate protection capabilities by using cryptographic measures to comply with the confidentiality, authenticity, integrity, and non-repudiation requirements of the transferred business information. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.14
19.2 DOR.ICT.EKM.EMC.003	A concept to identify and consider the integrity requirements of the data must be defined and implemented. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.14
19.3 DOR.ICT.EKM.EMC.004	For information which is classified as "strictly confidential" or "Data Crown Jewel"⁴, all communication should be encrypted. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Storage Media, Other Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.14

5. Roles and Responsibilities

5.1. Creator

The creator of the Encryption and Key Management Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of Encryption and Key Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Encryption and Key Management Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Encryption and Key Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk **Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual guideline review with material changes

Coordination before publication

Version	Date	Task	Name
2.0	09.04.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	08.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	08.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	Data Security Procedure

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
